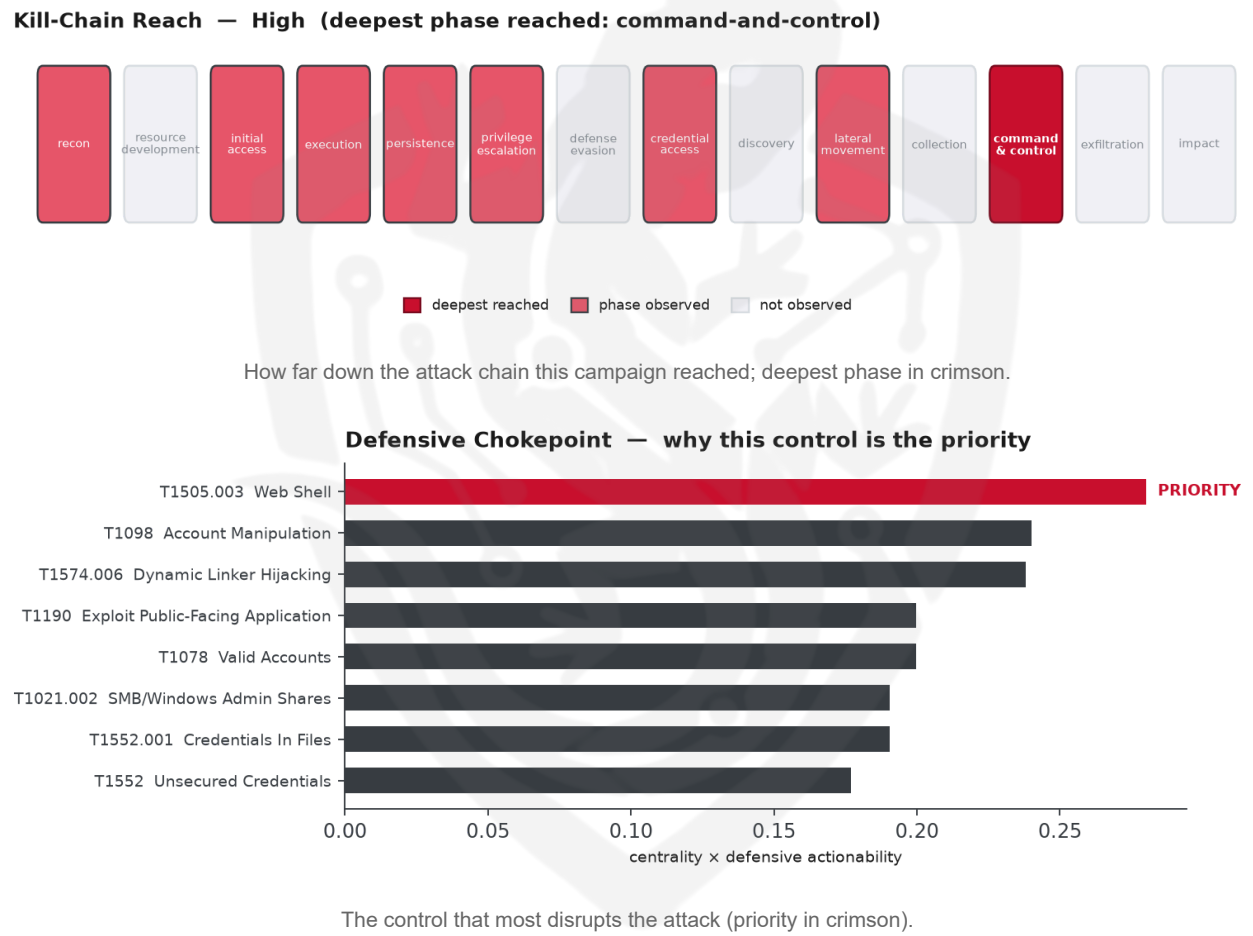


THREAT REPORT: THAI BROADBAND PROVIDER COMPROMISED VIA FORTIGATE SSL-VPN AND MESHCENTRAL

Visual Summary



Summary

The observed cluster of activity leveraged CVE-2024-21762 to gain initial access to a Thai telecommunications provider. Exploitation of FortiGate SSL-VPN services and deployment of MeshCentral enabled persistent remote access. The campaign targeted the telecommunications sector in Thailand, employing a range of credential-theft and lateral-movement techniques. Priority should be given to integrity-monitoring of web-server directories for web shells, restricting server module or plugin installation, and promptly patching CVE-2024-21762 on all affected systems.

Threat Overview

The threat actor remains unidentified, and no specific malware family was reported. The adversary exploited the public-facing FortiGate SSL-VPN vulnerability identified as CVE-2024-21762. Victims were telecommunications organizations operating in Thailand.

Attack Chain and Priority Control

The activity began with active and vulnerability scanning (T1595 Active Scanning, T1595.002 Vulnerability Scanning) to locate exposed services. The adversary then exploited the public-facing FortiGate SSL-VPN (T1190 Exploit Public-Facing Application) to establish external remote services (T1133). Persistence was achieved by installing a web shell on compromised web servers (T1505.003 Web Shell). From this foothold, the group performed credential dumping (T1003 OS Credential Dumping, T1003.003 NTDS), password guessing and brute-force attacks (T1110.001 Password Guessing, T1110 Brute Force), and leveraged valid accounts (T1078) to move laterally via SMB/Windows admin shares (T1021.002) and SSH (T1021.004). Additional techniques included account manipulation (T1098), exploitation for privilege escalation (T1068), and cleanup of artifacts (T1070 Indicator Removal, T1070.004 File Deletion).

Priority technique: T1505.003 Web Shell

Priority control: *Integrity-monitor web-server directories for web shells; restrict server module/plugin installation. In parallel, patch CVE-2024-21762 on all affected systems.*

Infrastructure and Corroboration

The malicious infrastructure appears to be hosted by Triple T Broadband Public Company Limited and Bangmod Enterprise Co. Ltd, as noted in the source pulse. AbuseIPDB reports no indicators associated with this activity at a confidence level of 80 % or higher (maximum observed confidence 0 %). Abuse.ch did not identify any corroborated malware families linked to the campaign.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1110.001 Password Guessing
- T1003 OS Credential Dumping
- T1133 External Remote Services
- T1021.004 SSH
- T1190 Exploit Public-Facing Application
- T1219 Remote Access Tools
- T1552 Unsecured Credentials
- T1021.002 SMB/Windows Admin Shares
- T1595.002 Vulnerability Scanning
- T1505.003 Web Shell
- T1574.006 Dynamic Linker Hijacking

- T1595 Active Scanning
- T1070 Indicator Removal
- T1552.001 Credentials In Files
- T1098 Account Manipulation
- T1110 Brute Force
- T1078 Valid Accounts
- T1068 Exploitation for Privilege Escalation
- T1070.004 File Deletion
- T1105 Ingress Tool Transfer
- T1003.003 NTDS

Analytical Scores

- Priority technique (graph chokepoint): T1505.003 Web Shell (centrality 0.3082).
- Operational risk: High (score 0.636, reaches command-and-control).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4629; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Volatile Cedar	0.4629
Ember Bear	0.3659
Fox Kitten	0.3611
FIN13	0.3536
Aquatic Panda	0.3499

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	92[.]63[.]180[.]133	AbuseIPDB 0% (TH) · AS58955 Bangmod Enterprise Co. Ltd
IP	110[.]164[.]129[.]67	AbuseIPDB 0% (TH) · AS45758 Triple T Broadband Public Company Limited
IP	110[.]164[.]192[.]228	AbuseIPDB 0% (TH) · AS45758 Triple T Broadband Public Company Limited
IP	110[.]164[.]58[.]195	AbuseIPDB 0% (TH) · AS45758 Triple T Broadband Public Company Limited
Domain	mail[.]3bb[.]co[.]th	
Domain	www[.]ayuthayatech[.]com	
Domain	agent[.]3bb[.]co[.]th	
Domain	ccs[.]jasmine[.]com	
Domain	openvpn[.]jasmine[.]com	
Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.		

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1505.003 Web Shell (persistence)
- **Observed here:** T1505.003 Web Shell was the only persistence technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1136 Create Account (persistence)
- **Basis:** of the 12+ groups that use Web Shell, this pairing runs 2.9x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1505.003 Web Shell blocked, the threat actor could preserve the same objective by pivoting to T1136 Create Account, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Alert on new local/domain account creation (Event ID 4720/4728); enforce approval workflow for account provisioning.

Also plausible (same tactic): T1112 Modify Registry (n=11, lift 2.0), T1205 Traffic Signaling (n=3, lift 4.0)

Detection and hardening for the pivot (T1136 Create Account)

- **Telemetry:** Windows Security (account management); IdP audit logs
- **Detect:**
 - Security 4720 (local user created), 4741 (computer account), 4728 (added to group)
 - New cloud/IdP accounts created outside HR/provisioning workflow
- **Harden:**
 - Restrict account creation to provisioning systems; alert on manual creation
 - Periodic review of recently created accounts
- **MITRE:** M1026 Privileged Account Management, M1032 Multi-factor Authentication · DS0002 User Account

